

NEWSLETTER N. 524 of June 6, 2024

Scientific Research: the Privacy Guarantor's FAQs for IRCCS

Public Administration Competitions: only the final rankings of winners online

Privacy Guarantor: GDPR also applies to Wikipedia

Cloud services for the Public Administration: Privacy Guarantor approves ACN Regulation

GDPR and artificial intelligence, the Report of the European task force on ChatGPT

Scientific Research: the Privacy Guarantor's FAQs for IRCCS

Scientific hospitals and care institutes can use data collected for clinical activities for further medical research purposes.

What are IRCCS? How can they use personal data collected for patient care for research purposes?

What obligations do they have under the Privacy Code? The Privacy Guarantor answered these questions with the FAQs now available on the website

<https://www.gpdp.it/temi/sanita-e-ricerca-scientifica/irccs>.

The Authority's clarifications are directed at IRCCS, which are entities of the National Health Service that, according to excellence standards, pursue research purposes in the biomedical field and in the organization and management of health services and provide high-specialty hospitalization and care services.

The FAQs explain that IRCCS, in order to use their patients' data for authorized scientific research activities by the Ministry, must identify a legal basis suitable to legitimize such processing and an appropriate exemption to the general prohibition on processing health and genetic data.

The Guarantor has thus clarified that both public and private IRCCS, in addition to relying on the consent of research participants, can base the processing of personal data collected for care purposes for further research purposes on Article 110-bis, paragraph 4 of the Privacy Code, according to which processing for research purposes does not constitute further processing of data collected for clinical activities.

In the event that IRCCS rely on this provision, they are, however, obliged to conduct an Impact Assessment (Vip) and publish it on their websites. However, if the full publication of the Vip could harm intellectual property rights, trade secrets, or other matters, the Institute may publish it in extract form. A specific section of the FAQs is dedicated to the different ways to inform research participants depending on whether the data is collected from them or from internal databases of the institute or other participating centers.

Finally, the Authority clarified the objective scope of application of Article 110-bis, paragraph 4 of the Code, which concerns all types of medical, biomedical, epidemiological, prospective, and retrospective research promoted by IRCCS, including multicentric studies, whether conducted within the research networks of IRCCS or in those promoted by such institutes with the participation of entities that do not have such recognition.

Public Administration Competitions: only the final rankings of winners online

The Guarantor sanctions INPS for unlawful dissemination of personal data

Publishing on the web the results of intermediate tests or the personal data of non-winning or non-admitted candidates in a competition is a violation of privacy.

Thus stated the Guarantor following a complaint filed by a participant in the public competition for 1858 positions as social protection consultant in the roles of INPS personnel.

The complainant had reported the publication on the Institute's website of numerous acts and documents, including the lists of those admitted and not admitted to the written and oral tests and the list of participants, containing the evaluation of qualifications by the Competition Commission, with the indication of the score assigned to each candidate. Such documents would then have ended up on social networks by third parties.

Public entities, the Guarantor reminded, when conducting competitive procedures must process the personal data of the interested parties in compliance with applicable sector regulations, and therefore it is not possible to publish online data of competition participants not provided for by law.

Differentiated levels of protection for personal data are not permitted, neither on a territorial basis nor

at the level of individual administrations, especially when the matter has already been subject to balancing and regulation by the legislator with uniform provisions at the national level.

In quantifying the amount of the sanction against INPS at 20,000 euros, the Authority considered the nature, duration, and severity of the violation, as well as the high number of interested parties and the cooperative attitude of the Institute, which removed the lists in question, albeit following the Guarantor's request for information.

****Privacy Authority: the GDPR also applies to Wikipedia****

The online encyclopedia must comply with the rules on journalism and the expression of thought

The measure has been challenged

The processing of personal data carried out by Wikipedia falls under the GDPR, and the published content is subject to the rules on journalistic activity and the expression of thought. This was established by the Authority for the Protection of Personal Data, following a complaint from an individual who had not seen their request for the deletion of a biographical article, related to a judicial matter, satisfied by Wikipedia Foundation, the US non-profit that created the online encyclopedia project.

Regarding the processing of personal data carried out in the articles, the Foundation, which has no establishment in Europe, believes that Wikipedia does not provide a service to users in the EU and is therefore not bound to comply with the General Data Protection Regulation: the encyclopedia would merely be a "neutral host" that "hosts" content submitted by the volunteer community.

In reality, Wikipedia not only provides an information service on a wide variety of topics, but it also targets the European market, as evidenced by the constant action of guidance and verification of the quality standards of the content directed by the Foundation to the community and the creation of site versions dedicated to users from one or more member states. Thus, the Authority explains, the requirement of intentionality in the offering of services is realized, which allows the application of the GDPR to a data controller established in a third country and without an establishment in the EU.

Clarifying the scope of application, the Authority rejected the request for deletion from the individual, as the processing of personal data for journalistic purposes, even without consent, is lawful if it respects the rights and dignity of individuals and the principle of the essentiality of information. Similarly, the permanence of the article in the online encyclopedia's archive is also lawful: the archives of websites and newspapers, including print ones, indeed play an important role in the historical reconstruction of events.

However, the Authority ordered the de-indexing of the article. The online presence of the page would indeed nullify the benefit of the limit of knowledge imposed on convictions of less than two years, which are not included in the criminal record, while in the meantime, public interest in the matter has waned.

****Cloud Services for the Public Administration: Privacy Authority approves ACN Regulation****

Favorable opinion from the Privacy Authority on the draft Regulation for digital infrastructures and cloud services of the Public Administration. The draft decree, prepared by the National Cybersecurity Agency (ACN), replaces the act previously adopted by the Agency for Italy's Digital (AGID).

The draft Regulation takes into account the indications provided by the Authority during the discussions. The document introduces a new article dedicated to the correct application of privacy regulations, aimed at ensuring control by Public Administrations over all parties involved in the processing of data. In particular, it assigns the role of data controllers to the Public Administrations, while operators of digital infrastructures and cloud service providers are designated as data processors.

The text also establishes the obligation for data processors to adopt measures that ensure timely and adequate information from the administrations in the event of a data breach, considering the volume and sensitivity of the data processed (health data, tax data). Data processors will then have to provide the Public Administrations with suitable tools to control the processing activities carried out by any sub-processors.

Regarding the transfer of data outside the European Economic Area, data processors will be required to comply with the instructions of the administrations and to provide them with any necessary information to assess the effectiveness of the measures adopted.

The Regulation is part of the Cloud Italy Strategy, implemented by the Department for Digital Transformation and ACN, which contains guidelines for the migration path to the cloud of data and digital services of the Public Administration, also thanks to the National Strategic Pole (PSN), as a cloud infrastructure created at the government's initiative.

****GDPR and Artificial Intelligence, the Report of the European Task Force on ChatGPT****

What are the principles of personal data protection applicable to ChatGPT? This is the question answered by the Report on the work of the task force of the European Data Protection Board (EDPB), created last year to promote cooperation among the national data protection authorities investigating OpenAI's chatbot.

In assessing its legality, the Report suggests distinguishing the different phases of processing: data collection for training, including web scraping or reuse of datasets; pre-processing, including filtering; training; prompts and outputs of

ChatGPT; training of ChatGPT with prompts.

Particular attention is given to web scraping. For data collection, OpenAI has identified the legal basis as the legitimate interest of the data controller. A condition that – the EDPB reminds – must be balanced with the rights and fundamental freedoms of the data subjects. Although investigations are still ongoing, the European Committee suggests some guarantees that could make legitimate interest lawful, such as defining collection criteria and excluding certain categories of data and sources (e.g., public profiles on social media). Additional measures that could be adopted might include the deletion or anonymization of personal data prior to the training phase.

Regarding special categories of data, for which specific consent characterized by a positive action is required, the measures could involve filtering, to be applied both to data collection, for example by selecting criteria, and immediately afterward, by eliminating them.

In addition to the lawfulness of data collection for the training of ChatGPT, the Report on the work of the task force analyzes the principle of fairness, according to which it is up to OpenAI to ensure compliance with the GDPR; the principle of transparency and the principle of accuracy, according to which the data controller should provide adequate information about the probabilistic nature of the chatbot output and explicitly refer to the fact that the generated text may be partial or fabricated. Also based on the principle of transparency, OpenAI should inform data subjects that the content produced by the user, namely the input provided to the system, is used to train the chatbot.

The European Committee finally emphasizes that it is mandatory for data subjects to be able to exercise their rights effectively. The Report is the result of preliminary assessments that do not prejudice the analysis that will be carried out by each national Authority within the ongoing investigations, opened before February 15, 2024, when OpenAI established a presence in Europe. From that date, the cross-border processing activities of the US company fall within the scope of the One-stop shop.

THE ACTIVITIES OF THE GUARANTOR - FOR THOSE WHO WANT TO KNOW MORE

The most important interventions and measures recently adopted by the Data Protection Authority: the twinning with Bosnia-Herzegovina begins – May 2, 2024

“Privacy Tour 2024.” The initiative of the Guarantor to promote the culture of data protection and the conscious use of new technologies in the South and in small towns. Second stop Lecce, April 20.

Next stop Messina, May 3

Privacy: bilateral, close cooperation initiated between the Italian Guarantor and the German Federal Guarantor - Press release of April 21, 2024

Privacy: bilateral between the Italian Guarantor and the German Federal Guarantor - Press release of April 18, 2024

NEWSLETTER of the Guarantor for the protection of personal data (Reg. at the Court of Rome No. 654 of November 28, 2002).

Responsible Director: Baldo Meo.

Direction and editorial office: Guarantor for the protection of personal data, Piazza Venezia, No. 11 -

00187 Rome.

Tel: 06.69677.2751 - Fax: 06.69677.3785

The newsletter is available on the website www.gdpd.it